Exposia

Revealing what exposes you

ANALYSIS REPORT

From threat to action: understand your exposure and prioritize your measures.

THREATS — ASSETS — RISKS — MITIGATIONS

ORGANIZATION	Exemple_en
ANALYZED DOMAIN	exemple.com
ANALYSIS DATE	October 18, 2026
CRITICALITY LEVEL	HIGH

CONFIDENTIAL — INTERNAL USE ONLY

FOREWORD

What this report says — and what it doesn't

This report describes your exposure **from the Internet**, from the point of view of an external attacker: **with no privileged access, and without ever touching your systems**. Every finding relies on public, recognised sources: published certificates, DNS, Shodan, the NIST vulnerability database (NVD), exploitation probabilities (EPSS) and public exploit repositories.

WHAT IT IS

A point-in-time snapshot of your external attack surface, prioritised by technical severity, likelihood of exploitation and business impact. A decision-making tool: it shows where to act first.

WHAT IT IS NOT

A penetration test. No vulnerability was exploited: most are inferred from the software versions advertised by the exposed services. A patch that has already been applied may go undetected if the advertised version has not changed. Unpublished assets and your internal network are out of scope. The attack scenarios are representative, and the sensitivity of a service is presumed from its nature.

Each finding is linked to its source and should be verified by your teams before any action is taken. The information presented is publicly accessible. Bringing it together gives a better understanding of your exposure and helps prioritise actions.

CONTENTS

Your report in five parts

Each part opens with an “In brief” box summarising the essentials: the summary is enough to make decisions, the following parts provide the detail.

SUMMARY

From threat to mitigation 4

PART 1 · THREATS

Who is targeting you, and why? 7

PART 2 · ASSETS

What is your exposed perimeter? 10

PART 3 · RISKS

What is the impact on your business? 13

PART 4 · MITIGATION

What should you actually do? 17

SUMMARY

From threat to mitigation

IN BRIEF

Our analysis reveals **6 attacker profiles** likely to exploit **27 vulnerabilities** on **27 exposed services**. The priority is **updating the affected software**. In addition, **52 measures** make up a roadmap to durably reduce exposure and focus efforts where they create the most value.

Methodology

Our approach combines four complementary strands to give you a clear, prioritised view of your risks:

- **Threat Modeling** — identifying the **most credible attackers** given your profile.
- **Asset Discovery** — mapping your **exposed perimeter** (subdomains, services, ports).
- **Risk Assessment** — highlighting **exploitable vulnerabilities** and **typical attack scenarios**.
- **Mitigation Plan** — selecting and ranking the most useful **good practices**.

Each chain below links a priority vulnerability to an attacker profile whose motivations are consistent with the potential impacts, to make the scenario and the response to it more concrete.

Threat chains

Scenario 1 CRITICAL

ACTOR	ASSET	VECTOR	MITIGATION
Organized crime Financial gain	**test-bastion01.exemple.com** 139.81.X.X:22	**Administrative access** CVE-2024-6387	**MIT-VULN-001** Covers 24 vuln.

A threat actor of the **Organized crime** type (motivation: **financial gain**) targets **test-bastion01.exemple.com** (139.81.X.X:22). By exploiting vulnerability **CVE-2024-6387** on your **Administrative access** service, the attacker fully compromises the system, accesses all sensitive data and can interrupt critical operations. The first measure is to **update the affected software**; measure **MIT-VULN-001** (“Establish an emergency patch deployment procedure”) helps durably reduce this type of risk.

Scenario 2 CRITICAL

ACTOR	ASSET	VECTOR	MITIGATION
State-sponsored Influence	**test-bastion01.exemple.com** 139.81.X.X:22	**Administrative access** CVE-2023-48795	**MIT-ANON-002** Covers 11 vuln.

A threat actor of the **State-sponsored** type (motivation: **influence**) targets **test-bastion01.exemple.com** (139.81.X.X:22). By exploiting vulnerability **CVE-2023-48795** on your **Administrative access** service, the attacker modifies critical information without affecting confidentiality or availability. The first measure is to **update the affected software**; measure **MIT-ANON-002** (“Define a clear authorization matrix by role and service”) helps durably reduce this type of risk.

Scenario 3 CRITICAL

ACTOR	ASSET	VECTOR	MITIGATION
Terrorist Disruption of operations	**test-bastion01.exemple.com** 139.81.X.X:22	**Administrative access** CVE-2023-38408	**MIT-COMP-001** Covers 5 vuln.

A threat actor of the **Terrorist** type (motivation: **disruption of operations**) targets **test-bastion01.exemple.com** (139.81.X.X:22). By exploiting vulnerability **CVE-2023-38408** on your **Administrative access** service, the attacker fully compromises the system, accesses all sensitive data and can interrupt critical operations. The first measure is to **update the affected software**; measure **MIT-COMP-001** (“Establish a continuity plan in case of major compromise”) helps durably reduce this type of risk.

Focus on the priority measures

MIT-EXPLOIT-001 — Covers 14 vulnerabilities

Set up a watch on published exploits for the technologies in use

MIT-VULN-001 — Covers 24 vulnerabilities

Establish an emergency patch deployment procedure

MIT-ANON-002 — Covers 11 vulnerabilities

Define a clear authorization matrix by role and service

PART 1 · THREATS

Who is targeting you, and why?

IN BRIEF

The analysis identified **6 attacker profiles** likely to target your organization. None reaches the critical level given your profile; the most relevant is **Organized crime**. The most common motivation is **“Disruption of operations”**, associated with **38% of potential attacks**.

Methodology

Our **threat modeling** approach cross-references your organization's profile — **sector, size, geographic zone and exposure level** — with the characteristics of **eight types of malicious actors**. We analyse their motivations — **espionage, profit, sabotage, influence** — to complete the threat analysis in light of your profile, then weight each actor against these same criteria in order to **rank them through probabilistic filtering**. In short: we identify **who may attack you, why, and how relevant each threat is to your profile**.

Threat prioritization matrix

RANK	ACTOR	PRIMARY MOTIVATION	PROFILE	LEVEL
1	**Organized crime**	Financial gain	Dual purpose (2)	HIGH
2	**State-sponsored**	Espionage	Multi-objective (4)	HIGH
3	**Terrorist**	Disruption of operations	Dual purpose (2)	MODERATE
4	**Cyber-mercenary**	Disruption of operations	Dual purpose (2)	MODERATE
5	**Hacktivist**	Disruption of operations	Dual purpose (2)	MODERATE
6	**Malicious hacker**	Challenge, fun	Targeted (1)	LOW

Detailed attacker profiles

ORGANIZED CRIME

Profile: Dual purpose • 2 active motivations

Sophistication: High • **Resources**: Substantial • **Probability**: High

TYPOLOGY

Driven by **financial profit**, these groups operate like criminal businesses, with structured business models (ransomware-as-a-service, banking fraud, data theft). They often target **small and medium-sized businesses** because of their greater vulnerability. Their attacks are generally **opportunistic** but well organised.

IDENTIFIED MOTIVATIONS

- **Financial gain**

  Level high × Resources substantial × Relevance very high

- **Disruption of operations**

  Level moderate × Resources significant × Relevance moderate

STATE-SPONSORED

Profile: Multi-objective • 4 active motivations

Sophistication: Very high • **Resources**: Unlimited • **Probability**: Very high

TYPOLOGY

These groups have **unlimited resources and cutting-edge expertise**. They operate over the long term with strategic objectives: **economic espionage**, **political influence**, **geopolitical positioning**, or **sabotage of critical infrastructure**. Their approach favours **stealth** and **persistence** to avoid detection.

IDENTIFIED MOTIVATIONS

- **Espionage**
  Level high × Resources unlimited × Relevance very high
- **Influence**
  Level high × Resources unlimited × Relevance very high
- **Strategic positioning**
  Level moderate × Resources significant × Relevance moderate
- **Disruption of operations**
  Level moderate × Resources significant × Relevance moderate

TERRORIST

Profile: Dual purpose • 2 active motivations

Sophistication: Medium to high • **Resources**: Substantial • **Probability**: Variable

TYPOLOGY

They use cyberspace to complement their physical actions: **propaganda**, **recruitment**, **symbolic sabotage**, or **psychological attacks** (e.g. website defacement). Their technical sophistication varies, but their media impact is often disproportionate.

IDENTIFIED MOTIVATIONS

- **Disruption of operations**
  Level high × Resources substantial × Relevance very high
- **Influence**
  Level moderate × Resources substantial × Relevance moderate

PART 2 · ASSETS

What is your exposed perimeter?

IN BRIEF

Your perimeter includes **75 subdomains** and **27 distinct services**, spread across **5 categories**. Among them, **4 presumed sensitive services** (administration, file transfer, database…): usually intended for internal use, they deserve a check of their accessibility from the Internet.

Methodology

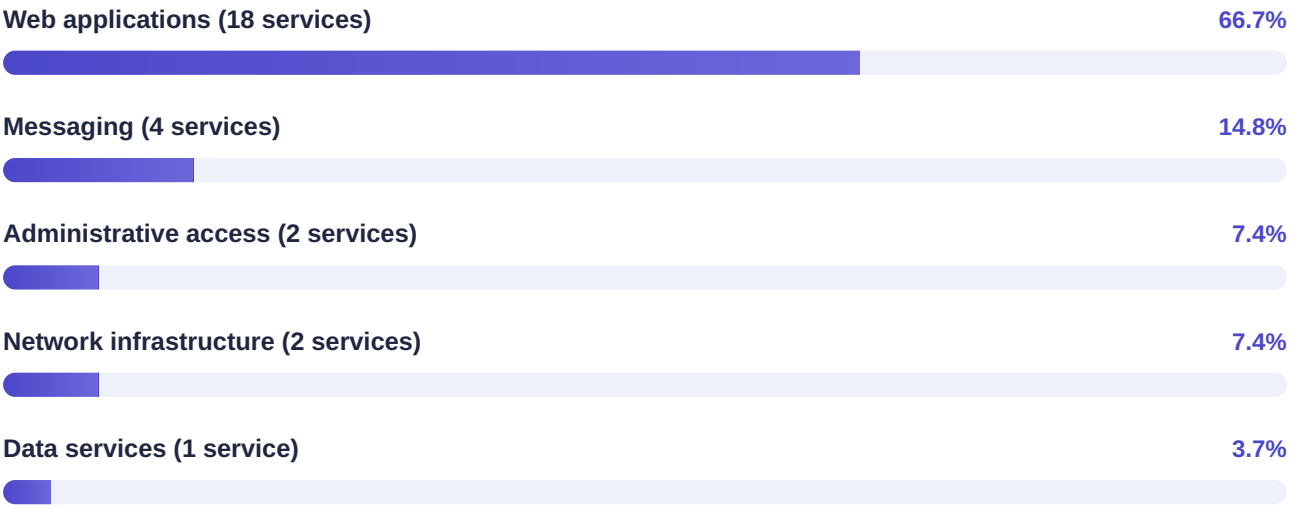
Our discovery relies exclusively on **passive, non-intrusive methods**, with no impact on your systems: analysis of public SSL certificates, DNS resolution and review of exposed services based on open data. Each service is categorised and qualified according to its **presumed nature**: **sensitive** when it is a type of service usually reserved for internal use, **standard** otherwise. Its **potential impact on your business** is then estimated from its criticality and exposure. In short: a **complete and actionable** inventory, obtained without ever touching your production.

Asset discovery matrix

RANK	SUBDOMAIN	SERVICE	CATEGORY	PRESUMED NATURE	IMPACT
1	test-bastion01.exemple.com	139.81.X.X:22	Administrative access	SENSITIVE	CRITICAL
2	test-bastion01.exemple.com	139.81.X.X:10250	Administrative access	SENSITIVE	CRITICAL
3	internal-web36.exemple.com	139.96.X.X:80	Web application	SENSITIVE	HIGH
4	internal-web36.exemple.com	139.96.X.X:443	Web application	SENSITIVE	HIGH
5	admin-web09.exemple.com	139.96.X.X:80	Web application	SENSITIVE	HIGH
6	admin-web09.exemple.com	139.96.X.X:443	Web application	SENSITIVE	HIGH
7	dev-web31.exemple.com	139.96.X.X:80	Web application	SENSITIVE	HIGH
8	dev-web31.exemple.com	139.96.X.X:443	Web application	SENSITIVE	HIGH
9	test-web08.exemple.com	139.96.X.X:80	Web application	SENSITIVE	HIGH
10	test-web08.exemple.com	139.96.X.X:443	Web application	SENSITIVE	HIGH

Presumed nature: inferred from the type of service (port, protocol, subdomain name). “Sensitive” flags a service usually reserved for internal use, to be confirmed with your teams.

Breakdown by service category



PART 3 · RISKS

What is the impact on your business?

IN BRIEF

We identified **27 vulnerabilities** and derived **36 distinct typical attack scenarios** from them (the same scenario may apply to several assets). Public exploits are referenced for some of the identified vulnerabilities: **120 exploits** are listed. Among your assets, **test-bastion01.exemple.com** stands out and requires particular attention. Attack vectors are concentrated on the **Administrative access** and **Network infrastructure** categories.

Methodology

Our approach combines **operational impact analysis** with **typical attack scenarios**, representative of common attacks on your exposed services and on the identified vulnerabilities. Each scenario is assessed according to its **contextual criticality**, which takes into account:

- **technical severity** (CVSS),
- the **likelihood of exploitation** (EPSS),
- the **business impact** of the service concerned (disruption, data leak, financial loss, compliance).

In short: understanding **how a technical threat can affect your business**, based on its likelihood and potential impact.

Risk prioritization matrix

RANK	ASSET	SERVICE	CRITICALITY	EXPLOITS	APPLICABLE SCENARIOS
1	**test-bastion01.exemple.com**	Administrative access (Port 22)	CRITICAL	120	27
2	**test-bastion01.exemple.com**	Network infrastructure (Port 179)	MEDIUM	0	0
3	**test-bastion01.exemple.com**	Administrative access (Port 10250)	MEDIUM	0	1
4	**internal-web36.exemple.com**	Web application (Port 80)	MEDIUM	0	1
5	**internal-web36.exemple.com**	Web application (Port 443)	MEDIUM	0	1
6	**web30.exemple.com**	Web application (Port 80)	MEDIUM	0	1
7	**web30.exemple.com**	Web application (Port 443)	MEDIUM	0	1
8	**web38.exemple.com**	Web application (Port 80)	MEDIUM	0	1
9	**web38.exemple.com**	Web application (Port 443)	MEDIUM	0	1
10	**web02.exemple.com**	Web application (Port 80)	MEDIUM	0	1

Typical attack scenarios on your critical assets

These scenarios illustrate how an attacker could exploit your most exposed services. When a specific vulnerability is involved, its reference (CVE) is given; the other scenarios describe common attacks on this type of service.

TEST-BASTION01.EXEMPLE.COM

Service Administrative access • 139.81.X.X • Ports 22, 10250 • Critical

Scenario #1 • CVE-2024-6387 • Critical

RECONNAISSANCE

A remote attacker searches for exposed services and can identify this vulnerability from the Internet

EXPLOITATION

The attacker could exploit this vulnerability without authentication, provided favourable circumstances are met (interception position on the network, specific configuration or time window)

IMPACT

The attacker fully compromises the system, accesses all sensitive data and can interrupt critical operations

Scenario #2 • CVE-2023-48795 • Critical

RECONNAISSANCE

A remote attacker searches for exposed services and can identify this vulnerability from the Internet

EXPLOITATION

The attacker could exploit this vulnerability without authentication, provided favourable circumstances are met (interception position on the network, specific configuration or time window)

IMPACT

The attacker modifies critical information without affecting confidentiality or availability

Scenario #3 • CVE-2023-38408 • Critical

RECONNAISSANCE

A remote attacker searches for exposed services and can identify this vulnerability from the Internet

EXPLOITATION

The attacker could exploit this vulnerability without authentication, possibly in an automated way

IMPACT

The attacker fully compromises the system, accesses all sensitive data and can interrupt critical operations

INTERNAL-WEB36.EXEMPLE.COM / WEB30.EXEMPLE.COM / WEB38.EXEMPLE.COM / WEB02.EXEMPLE.COM

Service Web application • 139.96.X.X • Ports 80, 443 • Medium

Scenario #1 • Common attack on this service • Medium

RECONNAISSANCE

An attacker scans the web application and identifies input fields vulnerable to SQL injection

EXPLOITATION

The attacker injects malicious SQL code to bypass authentication and access the database

IMPACT

The attacker extracts sensitive data, modifies information or deletes critical records

Scenario #2 • Common attack on this service • Medium

RECONNAISSANCE

An attacker scans the secured web application and identifies application vulnerabilities

EXPLOITATION

The attacker exploits OWASP Top 10 flaws despite HTTPS encryption

IMPACT

The attacker compromises user sessions and accesses the application's sensitive data

PART 4 · MITIGATION

What should you actually do?

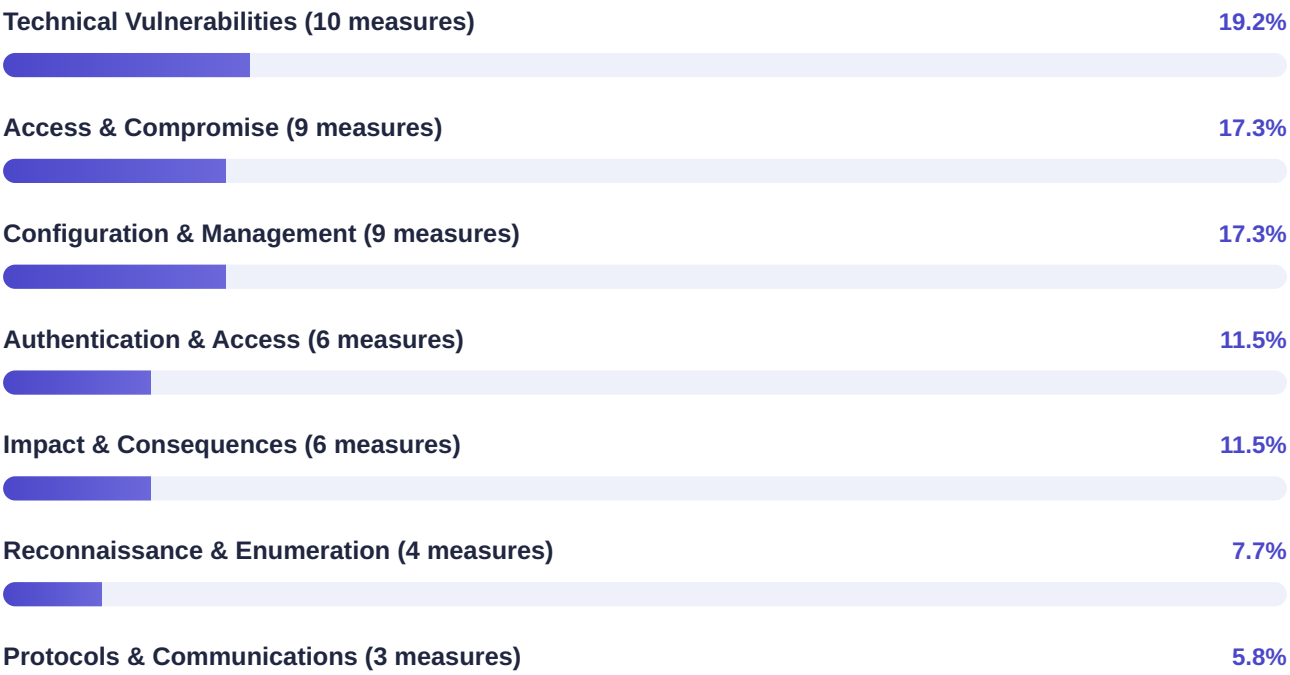
IN BRIEF

The **27 identified vulnerabilities** are mainly associated with potentially vulnerable software versions: addressing them starts with **applying the vendor updates**, beginning with the most exposed services.
The **52 measures** presented below are **complementary**: they are **good practices** that durably reduce your exposure, independently of any specific vulnerability. They are mostly **preventive (75%)**, complemented by **detective (21%)** and **corrective (4%)** measures. The top-priority measure is to **set up a watch on published exploits for the technologies in use** (MIT-EXPLOIT-001).

Methodology

The measures are selected from the **attack scenarios** associated with your exposed services and your vulnerabilities, then **ranked by priority**. Each measure is ranked according to its estimated effectiveness, its coverage of several types of threats and its ease of implementation. In short: a **clear, prioritised roadmap of good practices** that complements keeping your software up to date.

Breakdown by category





Development & Applications (2 measures) 3.8%



Specific Services (1 measure) 1.9%



Social Engineering & Email (1 measure) 1.9%



Containerization & Orchestration (1 measure) 1.9%



Measure prioritization matrix

RANK	ID	MEASURE	CATEGORY	VULNERABILITIES ADDRESSED	PRIORITY	DIFFICULTY
1	MIT-EXPLOIT-001	Set up a watch on published exploits for the technologies in use	Technical Vulnerabilities	14	HIGH	MEDIUM
2	MIT-VULN-001	Establish an emergency patch deployment procedure	Technical Vulnerabilities	24	CRITICAL	MEDIUM
3	MIT-ANON-002	Define a clear authorization matrix by role and service	Authentication & Access	11	CRITICAL	MEDIUM
4	MIT-ANON-001	Carry out a quarterly audit of access rights and service accounts	Authentication & Access	11	HIGH	LOW
5	MIT-DATA-001	Establish a data breach notification procedure	Access & Compromise	4	CRITICAL	HIGH
6	MIT-ESCAL-001	Establish an approval procedure for privilege changes	Access & Compromise	3	CRITICAL	MEDIUM
7	MIT-APP-003	Establish a procedure for reporting and fixing application vulnerabilities	Technical Vulnerabilities	—	HIGH	MEDIUM
8	MIT-APP-002	Make secure code reviews mandatory	Technical Vulnerabilities	—	HIGH	MEDIUM
9	MIT-COMP-001	Establish a continuity plan in case of major compromise	Access & Compromise	5	CRITICAL	HIGH

RANK	ID	MEASURE	CATEGORY	VULNERABILITIES ADDRESSED	PRIORITY	DIFFICULTY
10	MIT-APP-001	Train development teams on OWASP Top 10 vulnerabilities	Technical Vulnerabilities	—	CRITICAL	HIGH

Focus on the priority measures

Set up a watch on published exploits for the technologies in use MIT-EXPLOIT-001

14 vulnerabilities addressed by this measure.

Complementary measure: Implement execution protection mechanisms (DEP, ASLR, sandboxing)

Priority: HIGH • Difficulty: MEDIUM • Type: **Preventive**

Establish an emergency patch deployment procedure MIT-VULN-001

24 vulnerabilities addressed by this measure.

Complementary measure: Implement an automated, centralised patch management system

Priority: CRITICAL • Difficulty: MEDIUM • Type: **Preventive**

Define a clear authorization matrix by role and service MIT-ANON-002

11 vulnerabilities addressed by this measure.

Complementary measure: Enforce mandatory authentication on all exposed services

Priority: CRITICAL • Difficulty: MEDIUM • Type: **Preventive**

Carry out a quarterly audit of access rights and service accounts MIT-ANON-001

11 vulnerabilities addressed by this measure.

Complementary measure: Disable all unnecessary anonymous access on services

Priority: HIGH • Difficulty: LOW • Type: **Preventive**

Exposia

Your exposure changes every day.
So should your visibility.